

Datenschutz-Folgenabschätzung (DSFA) – Entwurf für den FreiKI-Betrieb

Hinweis: Dies ist eine Vorlage zur Orientierung gemäß Art. 35 DSGVO, keine Rechtsberatung. Eine konkrete DSFA muss von der jeweils betreibenden Institution selbst durchgeführt und dokumentiert werden, ggf. unter Einbindung des betrieblichen Datenschutzbeauftragten.

1. Beschreibung der Verarbeitung

System: FreiKI – KI-Assistent (Chat, Wissensrecherche/RAG, Transkription, Websuche, OCR, Automatisierung über n8n)

Betreiber: [Name der Institution einsetzen]

Verarbeitungsorte: Dedizierter Server (Cloud-Miete oder On-Premises), physisch in der EU/Deutschland

Zweck der Verarbeitung: Unterstützung von Mitarbeitenden bei Recherche, Texterstellung, Übersetzung, internem Wissensmanagement und Automatisierung wiederkehrender Aufgaben.

2. Notwendigkeit und Verhältnismäßigkeit

- Die Verarbeitung ist auf das für den jeweiligen Zweck erforderliche Maß beschränkt (Chatverläufe werden serverseitig nicht dauerhaft gespeichert, siehe Abschnitt 4).
- Es kommt ein lokal betriebenes Sprachmodell zum Einsatz; es findet keine Übermittlung an Drittanbieter-APIs (z. B. OpenAI, Google) statt.
- Datenminimierung: Wissensbereiche werden gezielt von Administrierenden befüllt, nicht automatisch mit beliebigen Daten.

3. Bewertung der Risiken für Rechte und Freiheiten betroffener Personen

Risiko	Eintrittswahrscheinlichkeit	Schwere	Bewertung
Unbefugter Zugriff auf den Server	gering (TLS, VPN/Tailscale-Zugriff, rollenbasierte Rechte)	hoch	gering bis mittel
Offenlegung sensibler Daten in Wissensbereichen durch fehlerhafte Rechtevergabe	gering bis mittel	hoch	mittel
Verarbeitung sensibler Daten (Gesundheits-, Sozialdaten) bei entsprechender Nutzung	abhängig vom Einsatzkontext	hoch	im Einzelfall zu bewerten
Ausfall des Servers / Datenverlust	gering bis mittel	mittel	gering

Fehlerhafte/halluzinierte KI-Antworten als Entscheidungsgrundlage	mittel	mittel	mittel – organisatorisch durch Nutzungsrichtlinie zu adressieren
---	--------	--------	--

4. Geplante Abhilfemaßnahmen

- **Keine dauerhafte Speicherung von Chatverläufen** serverseitig; Verlauf bleibt nur im Browser des Nutzers.
- **TLS-Verschlüsselung** für sämtliche Verbindungen (Caddy-Reverse-Proxy).
- **Rollen- und Bereichsrechte:** Zugriff auf Wissensbereiche granular steuerbar (Admin/Manager/User).
- **Admin-Zugriff nur per VPN** (Tailscale), kein öffentlicher SSH-Zugang.
- **Trennung von Secrets** (API-Keys, Passwörter) in `.env`-Dateien, nicht im öffentlich erreichbaren Verzeichnis.
- **Lokales LLM ohne Rückkopplung** an den Modell-Hersteller – keine Trainingsdaten-Weitergabe.
- **Regelmäßige Backups** der Datenbank und Konfiguration.
- **Nutzungsrichtlinie** für Mitarbeitende: KI-Antworten sind zu prüfen, keine ungeprüfte Übernahme bei kritischen Entscheidungen.

5. Empfehlung

Bei Einsatz von FreiKI für allgemeine Bürokommunikation und internes Wissensmanagement ist das Restrisiko nach Umsetzung der genannten Maßnahmen als **gering bis mittel** einzustufen. Werden besondere Kategorien personenbezogener Daten (Art. 9 DSGVO, z. B. Gesundheitsdaten) in Wissensbereichen verarbeitet, ist eine vertiefte Einzelfallprüfung mit dem betrieblichen Datenschutzbeauftragten erforderlich, insbesondere zur Zugriffsbeschränkung auf den jeweiligen Bereich.

6. Konsultation

Vor Inbetriebnahme wird die Einbindung des betrieblichen Datenschutzbeauftragten sowie ggf. der Mitarbeitervertretung empfohlen.

Erstellt am: _____

Verantwortlich: _____